RELATÓRIO DE ESTUDO PRÁTICO

Laboratórios de controle de acesso — PortSwigger Web Security Academy

Autora: Luna Ferreira Reges
Tipo de atividade: estudo prático em ambiente de laboratório controlado
Base documental: registro pessoal de 13 labs resolvidos
Última atualização do registro: 20/10/2026

Documento educacional. Os resultados descritos referem-se exclusivamente aos laboratórios da plataforma PortSwigger e não representam testes em sistemas de produção.

1. Resumo executivo

Este relatório consolida a prática realizada em 13 laboratórios da categoria Access control da PortSwigger Web Security Academy. Os exercícios exploraram falhas de autorização que permitem acesso a funcionalidades administrativas, alteração indevida de privilégios e exposição de informações pertencentes a outros usuários.

Os cenários foram investigados principalmente por inspeção de robots.txt e do código-fonte, uso das ferramentas de desenvolvedor do navegador e análise/modificação de requisições HTTP com Burp Suite Repeater e Cookie Manager. Em alguns exercícios, a conclusão do laboratório exigiu demonstrar o impacto previsto pelo desafio, como excluir um usuário de teste ou acessar dados de outra conta.

O conjunto evidencia um tema recorrente: controles de acesso não podem depender de caminhos ocultos, cookies ou parâmetros controlados pelo cliente, cabeçalhos HTTP, método da requisição ou etapas de interface. A autorização precisa ser validada no servidor para cada recurso e operação.

2. Objetivos

• Reconhecer padrões comuns de falhas de controle de acesso em aplicações web.
• Praticar a inspeção de rotas, código-fonte, cookies, parâmetros e requisições HTTP.
• Diferenciar escalada vertical de privilégios, acesso horizontal indevido e exposição de credenciais.
• Registrar evidências, impacto observado e lições de validação para aplicação futura em testes autorizados.

3. Escopo e metodologia

O escopo foi limitado aos laboratórios educacionais registrados no arquivo de estudo. Não há indicação de testes em ativos reais, varredura externa ou avaliação de infraestrutura de terceiros.

Procedimentos registrados: inspeção de /robots.txt e do código-fonte; análise da aba Network do DevTools; captura e repetição de requisições HTTP; alteração controlada de cookies, parâmetros, cabeçalhos, métodos HTTP e campos JSON; comparação de respostas como 200, 302 e 401; validação do resultado dentro do próprio laboratório.

4. Resultados consolidados

Os 13 registros detalhados abaixo foram agrupados por padrão de falha. Os nomes dos exercícios seguem o registro pessoal fornecido.

4.1 Unprotected admin functionality

Data registrada: 19/10/10/2026
Falha observada: Painel administrativo acessível sem autenticação após descoberta do caminho em robots.txt.
Validação no laboratório: Inspeção de robots.txt; acesso a /administrator-panel; exclusão do usuário de teste Carlos.

4.2 Unprotected admin functionality #2

Data registrada: 19/10/10/2026
Falha observada: Caminho administrativo exposto no código-fonte/front-end, sem validação de autenticação no servidor.
Validação no laboratório: Inspeção do código-fonte e Network; identificação da rota /admin-; exclusão do usuário de teste.

4.3 User role controlled by request parameter

Data registrada: 19/10/10/2026
Falha observada: Cookie de papel Admin aceito sem validação adequada, permitindo escalada vertical.
Validação no laboratório: Alteração do cookie Admin=false para Admin=true no Cookie Manager; acesso à função administrativa.

4.4 User role can be modified in user profile

Data registrada: 19/10/10/2026
Falha observada: Mass assignment: campo roleid enviado no JSON do perfil alterou o papel do usuário.
Validação no laboratório: Reenvio da requisição change-email com roleid: 2 no corpo JSON.

4.5 User ID controlled by request parameter

Data registrada: 19/10/10/2026
Falha observada: IDOR: alteração do parâmetro id permitiu acessar dados de outra conta, incluindo API key.
Validação no laboratório: Burp Repeater; substituição do id e identificação da conta Carlos.

4.6 User IDOR with GUID

Data registrada: 19/10/10/2026
Falha observada: Identificador GUID exposto como autor de posts e aceito para consultar conta de outro usuário.
Validação no laboratório: Navegação no blog; captura do GUID; requisição a /my-account?id=.

4.7 User ID controlled by request parameter with data leakage in redirect

Data registrada: 20/10/10/2026
Falha observada: A resposta de redirecionamento também continha dados sensíveis montados antes da checagem adequada.
Validação no laboratório: Comparação de requisições com sessão válida e inválida; análise de resposta 200 e 302.

4.8 User ID controlled by request parameter with password disclosure

Data registrada: 20/10/10/2026
Falha observada: Página de conta de administrador acessível por IDOR e senha real presente no HTML da resposta.
Validação no laboratório: Burp Repeater; inspeção do HTML retornado para id=administrator.

4.9 Insecure direct object references (download de transcript)

Data registrada: 20/10/10/2026
Falha observada: Endpoint de download baseado em identificador sequencial entregou transcript de outro usuário, contendo credencial.
Validação no laboratório: Live chat; alteração do número no caminho de download; inspeção do transcript do laboratório.

4.10 URL-based access control can be circumvented

Data registrada: 20/10/10/2026
Falha observada: Controle baseado na URL contornado por meio do cabeçalho X-Original-Url.
Validação no laboratório: Comparação de GET /admin com GET / e cabeçalho X-Original-Url: /admin.

4.11 Method-based access control can be circumvented

Data registrada: 20/10/10/2026
Falha observada: Autorização aplicada de forma inconsistente entre métodos HTTP aceitos pela mesma rota.
Validação no laboratório: Comparação de POST /admin-roles com GET e parâmetros equivalentes.

4.12 Multi-step process with no access control on one step

Data registrada: 20/10/10/2026
Falha observada: Etapa final de alteração de privilégio não validou a autorização de forma independente.
Validação no laboratório: Mapeamento do fluxo em etapas e envio direto da requisição de confirmação.

4.13 Referer-based access control

Data registrada: 20/10/10/2026
Falha observada: Servidor confiou no cabeçalho Referer para autorizar operação administrativa.
Validação no laboratório: Reenvio da requisição com Referer apontando para /admin.

5. Principais aprendizados

Autorização no servidor: ocultar rotas ou elementos da interface não impede acesso direto. Toda operação sensível precisa validar identidade, papel e permissão no back-end.

Confiança em dados do cliente: cookies, parâmetros, campos JSON e cabeçalhos como Referer ou X-Original-Url podem ser manipulados. Não devem ser usados isoladamente como prova de autorização.

Controle por objeto: identificadores sequenciais e GUIDs não substituem uma checagem de propriedade. Cada consulta deve verificar se o usuário autenticado tem permissão sobre o recurso solicitado.

Fluxos completos: a autorização deve ser aplicada em todas as etapas e em todos os métodos HTTP aceitos, incluindo confirmações e endpoints alternativos.

Exposição de dados: redirecionamentos e campos mascarados na interface não protegem informações caso o corpo da resposta ainda contenha os dados sensíveis.

Validação das sessões: durante os exercícios, foi observado que cookies/sessões podem mudar entre respostas. Antes de interpretar um 401 como falha de permissão, é necessário confirmar que a sessão ainda é válida.

6. Recomendações defensivas

• Aplicar autorização no servidor em cada endpoint, objeto e ação sensível.
• Negar por padrão e verificar permissões com base na identidade autenticada e no recurso solicitado.
• Usar lista explícita de campos permitidos para atualizações de perfil, evitando mass assignment.
• Não confiar em cookies de papel sem proteção e validação server-side; preferir estado de sessão controlado pelo servidor.
• Aplicar as mesmas regras de autorização a todos os métodos HTTP e a todas as etapas do fluxo.
• Não incluir senhas ou segredos em HTML, respostas de redirecionamento ou dados de interface.
• Criar testes automatizados de autorização para usuários com papéis e proprietários de recursos diferentes.

7. Limitações

Este documento foi elaborado a partir do registro pessoal dos exercícios. Ele não contém capturas de tela, arquivos de requisição/resposta, versões dos componentes ou evidências anexas para cada lab. As descrições resumem o que foi documentado e não constituem validação independente dos resultados.

Os efeitos destrutivos descritos ocorreram dentro dos desafios educacionais. Nenhuma conclusão sobre a segurança de sistemas reais pode ser extraída diretamente desses resultados.

8. Conclusão

A prática reforçou a identificação de falhas de controle de acesso em aplicações web, especialmente quando a aplicação confia em informações fornecidas pelo cliente ou não verifica a autorização junto ao recurso solicitado. O próximo passo recomendado é complementar o registro com evidências sanitizadas, uma explicação de causa raiz e reteste após correção, mantendo a distinção entre exercícios de laboratório e avaliações profissionais.

Referência de estudo: PortSwigger Web Security Academy — categoria Access control. Conteúdo organizado com base no arquivo pessoal “Labs resolvidos”, atualizado em 20/10/2026.